SafeNet | THE DATA PROTECTION COMPANY

eBanking Best Practices:

Key Strategies for Establishing an Identity and Transaction Protection Ecosystem

WHITEPAPER

Best Practices in eBanking

- Employ Strong User Authentication
- Ensure Transaction Integrity
- Don't Lose Sight of Data
- Align Security Mechanisms with Each Use Case
- Protect the Backend: Securing Digital Certificates and Cryptographic Keys
- Ensure Requisite Levels of Responsiveness, and Availability

Table of Contents

Executive Summary 2

Introduction: Battling the Sophisticated Attacks on Corporate eBanking 2

The Identity and Transaction Protection Ecosystem: What It Is, Why It Is Needed 3

Best Practices for Building an Identity and Transaction Protection Ecosystem

- Employ Strong User Authentication 3
- Ensure Transaction Integrity 3
- Align Security Mechanisms with Each Use Case 4
- Protect the Backend: Securing Digital Certificates and Cryptographic Keys 5
- Ensure Requisite Levels of Responsiveness, and Availability 6

SafeNet: Delivering Unparalleled Security and Value in Financial Services 6

SafeNet in eBanking 7

Conclusion 8

About SafeNet 8

Financial institutions are tasked not only with combating escalating threats, but also addressing myriad risk profiles.

Executive Summary

As attacks targeting corporate online banking (eBanking) applications grow more sophisticated and more frequent, financial institutions need to strengthen their defenses. This paper uncovers the key strategies that banks can employ in order to effectively and efficiently combat today's threats, and ensure identity and transaction security in eBanking.

Introduction: Battling the Sophisticated Attacks on Corporate eBanking

As the use of eBanking grows more ubiquitous, so too do the attacks of criminals. Consider just a few stats:

- Currently, the Anti-Phishing Working Group estimates that 39% of all computers are infected with malware designed to steal financial account information. [http://www.americanbanker.com/btn/25_3/defending-your-apps-1047009-1.html]
- Online banking account takeovers are growing at more than 150% per year and cybercriminals have robbed banks, businesses and municipalities of more than $3 billion. [http://www.americanbanker.com/btn/25_3/defending-your-apps-1047009-1.html]
- In 2012, the losses associated with account takeover and new account fraud each rose by approximately 50% over the previous year. [http://www.ababj.com/tech-topics-plus/identity-fraud-study-finds-year-to-year-increase-banks-responding-3781.html] Not coincidently, these two fraud types impact consumers severely, and they are historically highly difficult for financial institutions to detect and prevent.

Attacks are especially common in corporate eBanking, where, compared to consumer banking, the larger monetary values and more frequent transaction rates make for a more fruitful, and thus compelling, target for cyber criminals.

Compounding these clear risks is the fact that, today, corporate eBanking encompasses many use cases, ranging from account viewing to wealth management. Each use case has its own unique threats, user demands, and levels of risk. Therefore, financial services institutions are tasked not only with combating escalating threats, but are saddled with the cost and complexity of addressing myriad risk profiles, security approaches, and user types.

In the battle financial institutions are waging to secure eBanking applications, strong, multi-factor authentication is an essential first line of defense. But today, authentication on its own isn't enough.

This is true because the increased sophistication of man-in-the-browser (MitB) attacks, which are often perpetrated through Zeus, SpyEye, and other malware. Through social engineering and a host of sophisticated malware exploits, cyber criminals can effectively insert themselves in between the end user and the bank during a transaction. When the bank requests authentication, the cybercriminal intercepts the credentials sent from the user. Thus, the criminal can submit the required details, and the bank will respond to the criminal as if he or she were a legitimate user.

One recent example of this type of attack is a variant of the Zitmo (Zeus in the mobile) malware that was found to be infecting Android and BlackBerry devices that defeats two-factor authentication. Responsible for the compromise of more than 30,000 user devices in Europe, the malware is reported to have resulted in the theft of 36 million Euros. [http://threatpost.com/en_us/blogs/zitmo-trojan-variant-eurograbber-beats-two-factor-authentication-steal-millions-120612]

Financial institutions need to establish an identity and transaction protection ecosystem, that enables them to meet not only their risk management mandates, but their cost and usability objectives as well to combat attacks.

In addition, the high-balance accounts owned by businesses or high net-worth individuals are now being targeted by sophisticated fraud automation techniques. These automated campaigns combine malware-based Web injection with server-hosted scripts in order to piggyback on active online banking sessions and initiate fraudulent transfers in real time.

Through an attack researchers dubbed "Operation High Roller," transactions conducted with banks throughout North America and Europe were targeted by an automated attack that bypassed two-factor authentication systems. The malware intercepted the authentication process and captured the one-time passwords generated by the victim's bank-issued hardware token, and then uses the password d to perform fraud. Over the course of a few months, it is believed criminals attempted to steal between $75 million and $2.5 billion from banks in Europe and North America. [http://www.computerworld.com/s/article/9228527/Cybercriminals_increasingly_use_online_banking_fraud_automation_techniques]

The Identity and Transaction Protection Ecosystem: What it is, Why it is Needed

To combat the types of attacks outlined above, financial institutions need to establish an identity and transaction protection ecosystem, one that enables them to meet not only their risk management mandates, but their cost and usability objectives as well. To achieve these ends, organizations need a comprehensive, adaptable, and robust security platform that enables them to continuously address emerging threats. Further, this platform must protect the entire eBanking ecosystem, including user identities, transactions, and the back-end infrastructure. The following section offers some essential best practices for building an identity and transaction protection ecosystem.

Did You Know?

In 2011, nearly half of financial institutions either already have or plan to implement multi-factor authentication.

Employ Strong User Authentication

Financial services institutions must have the controls in place to ensure that only authorized customers can access corporate eBanking resources and accounts. Toward this end, strong, multi-factor authentication continues to be essential. Multi-factor authentication refers to the identification of users through more than one factor, for example, something a user knows (such as a password), has (such an authentication token), or is (including biometrics).

For years, many financial institutions have been leveraging multi-factor authentication for a wide range of purposes—and it is, and will remain, a critical building block as organizations set out to establish an identity and transaction protection ecosystem. For those organizations that haven't yet invested in and deployed multi-factor authentication in corporate eBanking, there are a range of key best practices for establishing a secure and efficient authentication environment. For more information on this topic, download "A Fully Trusted Authentication Environment: Authentication Best Practices White Paper."

Ensure Transaction Integrity

While multi-factor authentication remains a critical security requirement, companies can no longer rely on this as their only line of defense. In case attackers find a way to circumvent strong authentication methods, banks need to have a second line of defense in place. It is incumbent upon financial institutions to ensure the integrity of a requested transaction before it is allowed to proceed.

Beneficial approaches for verifying transactions:

- **Knowledge-based challenge-response**
- **Out of band (OOB) authentication**
- **Digital signature**

To accomplish these objectives, financial institutions can leverage similar approaches that they've historically employed for user identification, including knowledge-based authorization, in which the user answers a security question when attempting to conduct a transaction initiated from an unknown computer, during an atypical time, as well as other alternatives, such as challenge-response and digital signatures. Today, these approaches are needed to augment the multi-factor user authentication mechanisms in place and ensure the validity of the transaction itself. Simply put, even if a user has been authenticated, high-value transactions should always be validated as well. Here's a brief overview of several approaches for verifying transactions:

- **Knowledge-based challenge-response.** . In this example, a user would initiate a transaction on a bank's online portal. Before executing the transaction, the bank could then prompt the user to submit such personal information as the spouse's maiden name or father's middle name. If the information submitted matches the bank's records, the transaction would be carried out.
- **Out of band (OOB) authentication.** Here's an overview of how the process works when OOB authentication is employed for transaction validation: When a customer initiates an eBanking transaction, a text message or phone call containing a one-time password is sent to the customer's mobile phone number. The customer must then provide that password on the website in order to complete the transaction.
- **Digital signature.** When digital signatures are employed, once a user views an eBanking transaction, a signing process would be initiated. This process starts by prompting the user for a token or PIN credential. Once the credential has been submitted, it is sent to a trusted certificate authority for validation. Finally, the recipient would view the signed transaction.

Out-of-band transaction security approaches are especially critical for higher value corporate customer services.

Each of the above approaches offer benefits. However, given its reliance upon personal information, which can be obtained through social engineering and other means, the first approach will typically be better suited to lower-value, lower-risk use cases. On the other hand, OOB approaches are especially critical for higher value corporate customer services. In the following section, we offer more information on aligning security mechanisms to use cases.

Align Security Mechanisms with Each Use Case

Banks and insurance companies are implementing multi-factor authentication in response to data breaches, compliance mandates, and to improve ease of use for end users. In corporate eBanking, different customers are vulnerable to varying risks, depending on the type of transactions they conduct and the value associated with those transactions. For example, account viewing and digital loan applications would be at the lower end of the risk continuum. At the higher end would be such transactions as online trading, fund transfers, and wealth management.

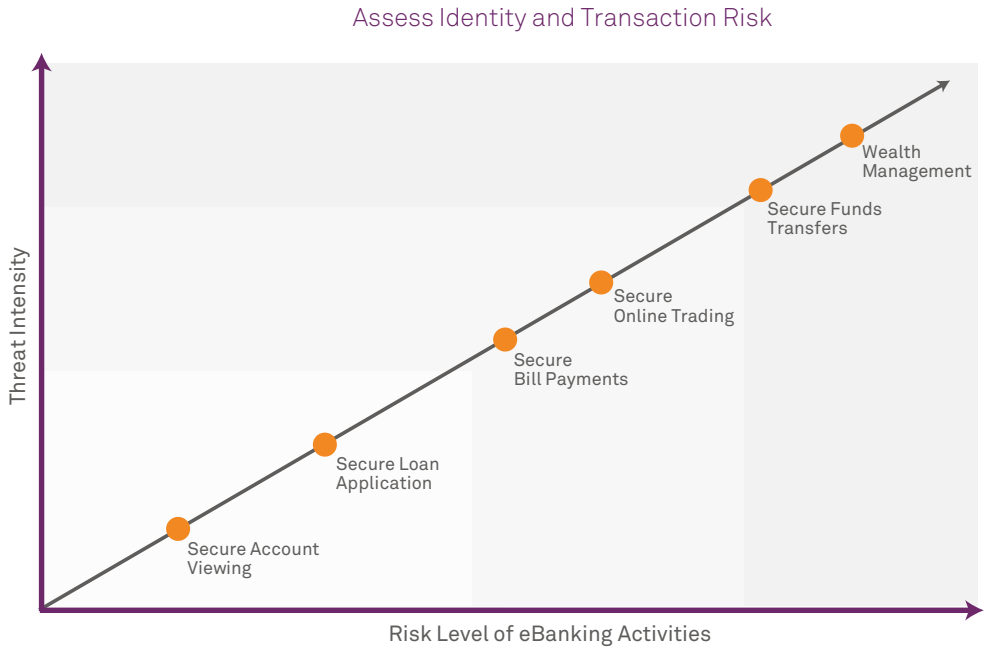
In addition to taking the type of transaction into consideration, Forrester's financial services clients are saying that they segment their client base when making decisions about which form factor of strong authentication to use. For example, high-value clients receive transaction signing hardware or software tokens that require a PIN to operate, while lower-value clients receive one-time passwords on their mobile phone. While some banks have looked at using biometrics (fingerprint, iris, etc.), reader costs and reader authentication present great cost and complexity that financial services companies cannot absorb. Companies also mention that building a unified framework for authentication (often integrated with Web SSO) that supports switching and reconfiguring different form factors of strong authentication play a critical role in vendor selection.

Did You Know?

The estimated cost of a data breach is between $90-300 per record, depending on the type of data, and can total an average of $7.2 million.

Consequently, a financial institution may enforce a number of policies with these varying risk levels in mind. So, for example, a bank may not require OOB transaction verification when a strongly authenticated corporate customer requests a payment to a vendor that the customer has an established relationship with.

On the other hand, OOB transaction verification may be required when payments are requested for a new vendor. Additional transaction verification may also be needed when payments exceed a volume or frequency threshold, such as more than $1,000 a day or more than 10 transactions a day. Enforcing these types of policies must be a critical priority for financial institutions today. It is clear these types of approaches would have prevented many of the breaches—and the associated lawsuits and financial penalties—outlined earlier.



There are varying risk levels and threats associated with different eBanking transactions. Organizations need to tailor security mechanisms and approaches based on these factors.

Protect the Backend: Securing Digital Certificates and Cryptographic Keys

Public key infrastructures (PKI) are relied upon to secure a broad range of corporate eBanking applications, and thus they represent a critical point of failure: If any of the back-end systems are compromised, the cost ramifications and security risks can be huge.

PKI represents a set of capabilities needed to issue, manage, and revoke the digital certificates used to authenticate any application, person, device, process, or organization. The building blocks of PKI include cryptographic keys, digital certificates, and digital signatures.

For authentication implementations built on PKI (certificate-based authentication), additional back-end security is often implemented to protect root keys and digital certificates issued by a Certificate Authority. To sustain the required levels of trust, it is imperative to institute and enforce policies that control the issuance of certificates, the administration and management of certificates and keys, and system access. When organizations institute appropriate policies and security measures, users can trust the legitimacy of the keys managing certificates and the entities issuing certificates.

Different customers are vulnerable to varying risks, depending on the type of transactions they conduct.

Additionally, for OTP authentication infrastructures, layered protection should be added to protect and control critical encryption keys and OTP seed data. Servers often play a fundamental role in an authentication infrastructure, acting as a central repository for cryptographic keys. As a result, a breach of these systems can compromise the integrity of the entire infrastructure. Too often, general purpose servers are used, which store keys in software, leaving memory unprotected and keys in clear text. On the other hand, hardware security modules (HSMs) can digitally sign hardware-based backup mechanisms to apply physical security mechanisms to keys. Applications communicate with keys stored in the HSM via a client—but keys never leave the HSM.

Ensure Requisite Levels of Responsiveness, and Availability

For corporate eBanking transactions, the need for real-time processing is imperative as it can make the difference between getting the best deal on a trade or ensuring money is transferred on time to fund a transaction. Further, given consumers' heightened awareness of malware and threats, delays and sluggish performance can give customers reason to doubt the security of a transaction.

That's why it's essential that when financial institutions implement validation mechanisms, these systems make it as easy as possible for end users to conduct transactions. The systems used to secure the eBanking application need to be reliable, scalable, and responsive. Further, the authentication method used to conduct the transaction must align with user expectations, and not act as a barrier to conducting business.

Ensuring the requisite levels of performance is especially critical for larger financial institutions, which need to ensure scalability to support a large user community, high volume transactions, and timely response—even when complex transactions and security mechanisms are deployed.

SafeNet: Delivering Unparalleled Security and Value in Financial Services

Leading financial services organizations around the world rely on SafeNet to secure their most vital assets—including their data, their customers, and their brand. SafeNet offers the innovative, comprehensive array of security solutions that enable financial institutions to meet their security needs—and their business objectives. Today, SafeNet protects:

- 80% of the world's intra-bank fund transfers—representing approximately $1 trillion worth of funds each day.
- Transactions for five of the world's largest central banks.
- The majority of ATM transactions in Europe, the Middle East, and Asia.
- The majority of PKI digital identity keys in America's top financial institutions.

Financial services (such as eBanking, digital processes, credit card processing, and electronic payments) can all be secured with SafeNet solutions. Whether organizations are looking to consolidate disparate operations or achieve regulatory compliance, SafeNet offers the advanced, broad range of solutions that can help.

Did You Know?

A 2010 American Banking Association survey showed that online banking is preferred over all other methods of banking.

Layered protection should be added to protect and control critical encryption keys and OTP seed data.

SafeNet in eBanking

As this paper has shown, today's threats to eBanking applications should be defended by strong authentication, transaction integrity validation, and back-end system security—all appropriate to the budgetary and usability objectives for each use case. SafeNet has many options for financial service providers to use in all these areas of defense. In addition, these solutions can be managed by a centralized system that requires the least amount of management overlap, making the solutions very cost-effective.

Only SafeNet enables financial services organizations to establish an identity and transaction protection ecosystem that enables them to realize these key objectives:

Whether organizations are looking to consolidate disparate operations or achieve regulatory compliance, SafeNet offers the advanced, broad range of solutions that can help.

- **Mitigate risk.** SafeNet solutions can authoritatively verify the identity of users and validate the integrity of transactions using all the best practices defined above. SafeNet is also the only vendor that can provide end-to-end financial services protection by comprehensively securing the authentication and cryptographic key infrastructure. This allows companies to quickly adapt to changing business needs and tailor levels of security to levels of risk involved with each type of service and each type of financial customer.
- **Streamline Management and Control costs.** SafeNet Authentication eliminates complex and costly IT infrastructures using a single management platform that supports multiple use cases while provisioning a wide range of tokens. SafeNet Authentication automates everything, drastically reducing the time and cost of provisioning, administration, and management of users and tokens compared to traditional authentication models.
    - **SafeNet Authentication Service.** SafeNet Authentication Service delivers fully-automated, highly secure authentication-as-a service with flexible token options that are tailored to the unique needs of your organization and substantially reduces the total cost of operation.
    - **SafeNet Authentication Manager.** SafeNet Authentication Manager is a comprehensive authentication server that allows organizations to implement a future-ready strong authentication strategy for securing local and remote access to numerous corporate resources using a single authentication back-end.

Did You Know?

The world's largest PKI implementation to date is the U.S. Government's Defense Information Systems Agency (DISA) PKI infrastructure for the Common Access Cards program.

eBanking Activity	SafeNet Solutions	Advantages	Benefit
Accounts Inquiries	• GrIDsure • MobilePASS	A range of hardware and software OTP solutions including SMS, with easy self-enrollment features.	Single server authentication manager reduces IT burden and enable future growth and scalability.
Bill payment and presentment	• MobilePASS • GOLD PIN • GOLD CR • eToken 3500 OTP w/ Optical Signing	The ease of OTP extended to include transaction security, through optical signing, and challenge-response – all in the same device.	
Online trading Funds transfers Wealth management	• eToken PRO Anywhere • eToken 3500 OTP w/ Optical Signing • Secure browser	Purpose-built solutions for high risk/high value transactions, including customer-friendly features like portable trusted browser and clientless smart card USB.	
Back-end systems Applications Transactions	• SafeNet HSMs	With numerous interfaces and modules customized for unique banking application environments, SafeNet HSMs are easy to integrate.	Central administration and remote PED reduce time and effort to manage.

SafeNet's Solution Portfolio for eBanking

0	9	5	7	3	4	8
1	4	8	8	2	2	2
1	0	5	6	1	5	9
2	6	7	3	0	6	0
6	3	1	8	4	2	7
7	1	4	9	4	3	0
9	7	5	5	8	9	6

GrIDsure

GrIDsure Authentication
Provide a flexible method for end-users to generate an OTP without hardware tokens or software applications.

MobilePASS
Software generated one-time passwords (OTPs) for convenient and secure two–factor authentication.

GOLD
Highly effective two-factor OTP authenticator that offers the added security of PIN protection and challenge-response.

eToken 3500
Combines secure transaction signing and OTP strong authentication, reducing the risk of online financial fraud.

eToken Pro Anywhere
The industry's first readerless smartcard token to combine strong, certificate-based authentication, complete mobility, and plug-and-play simplicity in a single device.

Luna G5
The SafeNet Luna G5 offers the strictest hardware security for Certificate Authorities (CAs) issuing digital identities in PKIs.

Luna SA
Luna SA is a network-attached general-purpose HSM device supporting the widest range of operating systems and cryptographic APIs.

Conclusion

For financial services institutions, building an ecosystem for protecting identities and transactions is a vital mandate. With SafeNet, these organizations gain the capabilities they need to effectively guard against sophisticated, evolving threats, so they can achieve their risk management objectives. In addition, with SafeNet's comprehensive, flexible, and scalable solutions, banks can meet their risk management objectives—and their objectives for cost management and usability.

About SafeNet

Founded in 1983, SafeNet is a global leader in information security. SafeNet protects its customers' most valuable assets, including identities, transactions, communications, data and software licensing, throughout the data lifecycle. More than 25,000 customers across both commercial enterprises and government agencies and in over 100 countries trust their information security needs to SafeNet.

Contact Us: For all office locations and contact information, please visit **www.safenet-inc.com**
Follow Us: www.safenet-inc.com/connected

©2013 SafeNet, Inc. All rights reserved. SafeNet and SafeNet logo are registered trademarks of SafeNet.
All other product names are trademarks of their respective owners. WP (EN)-05.08.13